

Bonus 1: Interpretare Dati HTTP e DNS per Isolare l'Attore della Minaccia

- **Parte 1:** Investigare un Attacco di **SQL Injection**
- **Parte 2:** Investigare l'Esfiltrazione di Dati **DNS**



MySQL è un popolare database utilizzato da numerose applicazioni web. Sfortunatamente, l'**SQL injection** è una tecnica comune di hacking web. È una tecnica di iniezione di codice in cui un attaccante esegue istruzioni SQL malevole per controllare il server database di un'applicazione web. I server dei nomi di dominio (DNS) sono directory di nomi di dominio e traducono i nomi di dominio in indirizzi IP. Questo servizio può essere utilizzato per **esfiltrare** dati.

Il personale di cybersecurity ha determinato che si è verificato un **exploit** e che dati contenenti PII (Personally Identifiable Information - Informazioni di Identificazione Personale) potrebbero essere stati esposti ad attori della minaccia. In questo laboratorio, userai **Kibana** per investigare gli exploit per determinare i dati che sono stati esfiltrati usando HTTP e DNS durante gli attacchi.



Parte 1 - Investigare un Attacco di SQL Injection

In questa parte, investigherai un **exploit** in cui è stato effettuato un accesso non autorizzato a informazioni sensibili memorizzate su un server web. Userai **Kibana** per determinare la fonte dell'attacco e le informazioni a cui l'attaccante ha avuto accesso.

È stato determinato che l'exploit è avvenuto in un momento durante il mese di giugno 2020. Kibana mostra per impostazione predefinita i dati delle ultime 24 ore.

Dovrai cambiare le impostazioni temporali per vedere i dati del mese di giugno 2020.

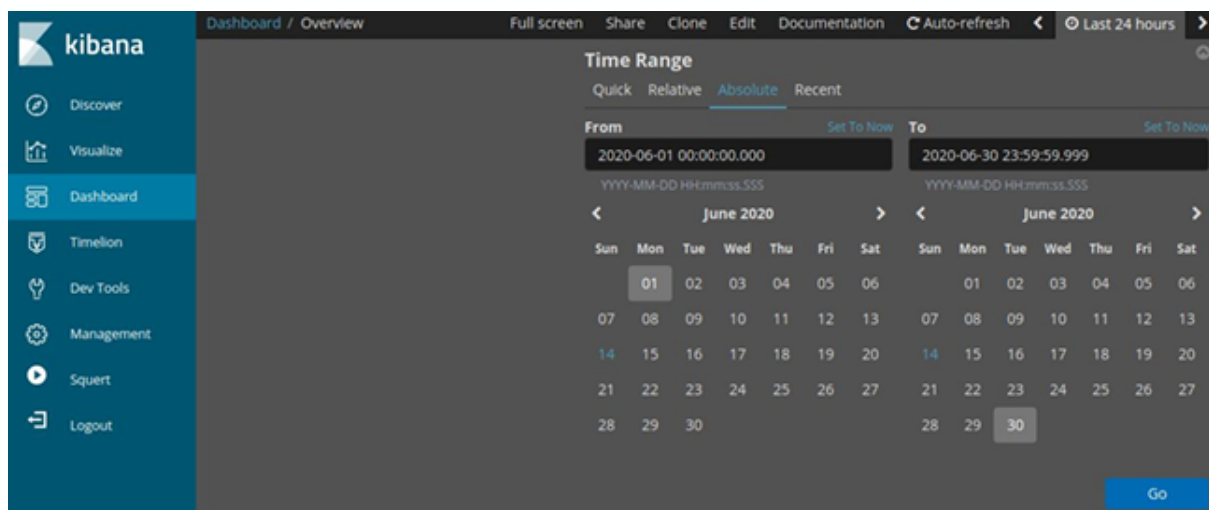
- Avvia la **VM Security Onion** ed effettua il login con il nome utente **analyst** e la password **cyberops**.
- Inserisci il comando `sudo so-status` per controllare lo stato dei servizi. Lo stato per tutti i servizi dovrebbe essere OK prima di iniziare l'analisi. Questo potrebbe richiedere alcuni minuti.

```
analyst@SecOnion:~$ sudo so-status
Status: securityonion
  * sgul server [ OK ]
Status: seconion-import
  * pcap_agent (sgul) [ OK ]
  * snort_agent-1 (sgul) [ OK ]
  * barnyard2-1 (spooler, unified2 format) [ OK ]
Status: Elastic stack
  * so-elasticsearch [ OK ]
  * so-logstash [ OK ]
  * so-kibana [ OK ]
  * so-freqserver [ OK ]
```

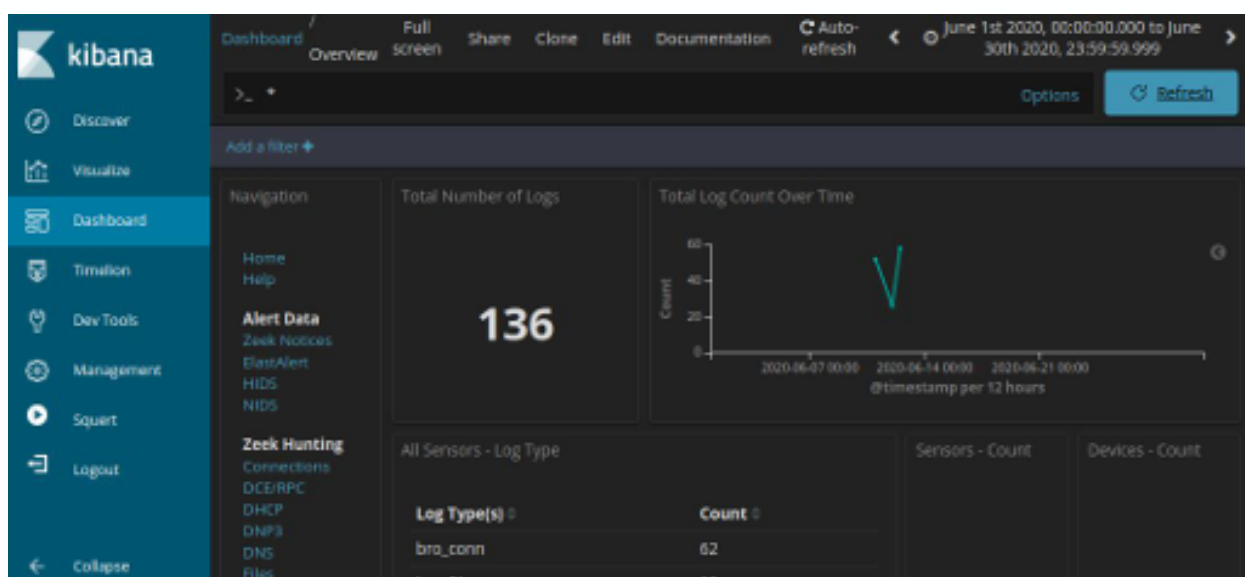
Dopo aver effettuato il login, apri Kibana usando il collegamento sul Desktop. Effettua il login con il nome utente **analyst** e la password **cyberops**. In Security Onion, Kibana ha molti dashboard e visualizzazioni predefinite per il monitoraggio e l'analisi. Puoi anche creare i tuoi dashboard e visualizzazioni personalizzate per monitorare il tuo particolare ambiente di rete.

Nota: Il tuo dashboard potrebbe non avere risultati nelle ultime 24 ore.

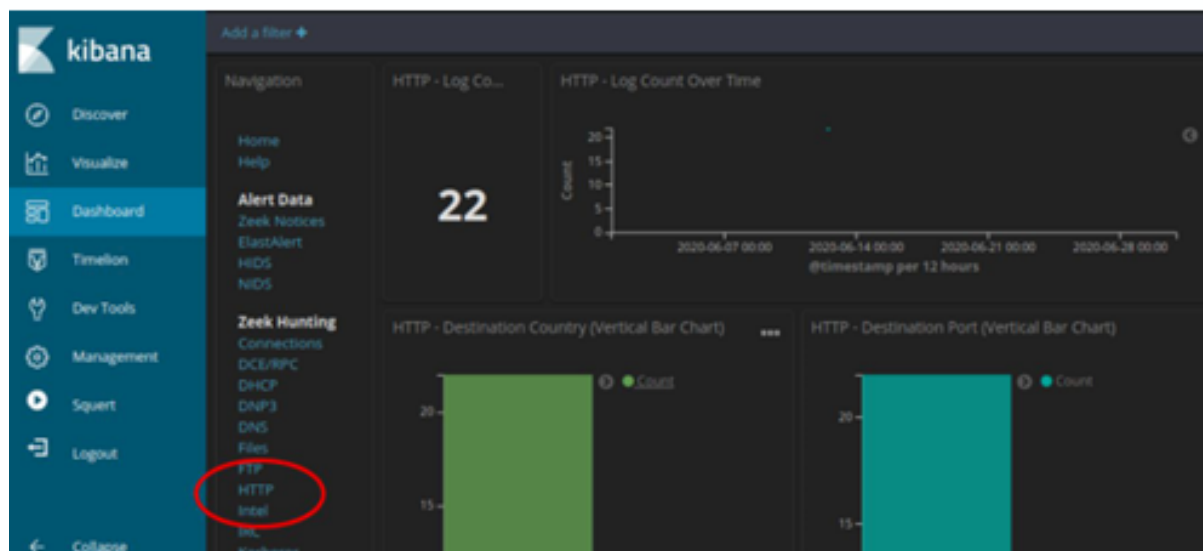
Nell'angolo in alto a destra della finestra, fai clic su Last 24 hours per cambiare la dimensione dell'intervallo di tempo campione. Espandi l'intervallo di tempo per includere gli alert interessanti. Un attacco **SQL injection** ha avuto luogo nel giugno 2020, quindi è quello che devi targetizzare. Seleziona Absolute sotto Time Range e modifica gli orari From e To per includere l'intero mese di giugno nel 2020. Fai clic su Go per continuare.



Nota il numero totale di log per l'intero mese di **giugno 2020**. Il tuo dashboard dovrebbe essere simile a quello mostrato nella figura. Prenditi un momento per esplorare le informazioni fornite dall'interfaccia Kibana.



Filtra per traffico **HTTP**, Poiché l'attore della minaccia ha avuto accesso a dati memorizzati su un server web, viene utilizzato il filtro HTTP per selezionare i log associati al traffico HTTP. Seleziona HTTP sotto l'intestazione **Zeek Hunting**, come mostrato nella figura.



Qual è l'indirizzo IP sorgente?

L'indirizzo ip sorgente è: **209.165.200.227**

HTTP - Source IP Address	
IP Address	Count
209.165.200.227	22



Qual è l'indirizzo IP destinazione?

L'indirizzo IP destinazione è: **209.165.200.235**

HTTP - Destination IP Address	
IP Address	Count
209.165.200.235	22



Qual è il numero di porta destinazione?

Il numero di porta di destinazione è la: **80** (considerando che era una connessione http è normale che sia 80)

Time	source_ip	destination_ip	destination_port
June 12th 2020, 21:30:09.445	209.165.200.227	209.165.200.235	80

Scorri verso il basso fino agli **HTTP Logs**. I risultati elencano i primi 10 risultati.

Espandi i dettagli del primo risultato facendo clic sulla freccia accanto al timestamp della voce di log. Nota le informazioni disponibili



Qual è il timestamp del primo risultato?

Il primo timestamp risale al **12 giugno 2020** alle ore 21:30:09.445



Qual è il tipo di evento?

Il tipo di evento è un: **bro_http**



Cosa è incluso nel campo message?

Nel message ci sono vari dettagli:

```
message [{"ts":"2020-06-12T21:30:09.445000Z","uid":"CmW8GdJyNvRfge","id.orig_h":"209.165.200.227","id.orig_p":56184,"id.resp_h":"209.165.200.235","id.resp_p":80,"trans_depth":1,"method":"GET","host":"209.165.200.235","uri":"/multiload/index.php?pageuser-info.php&username=unionselectccid,ccnumber,ccv,expiration,null+from+credit_cards+--&password=duser-info.php-submit-buttonV1+Account+Details","referrer":"http://209.165.200.235/multiload/index.php?pageuser-info.php","version":"1.1","user_agent":"Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0","request_body_len":0,"response_body_len":23065,"status_code":200,"status_msg":"OK","tags":["HTTP:URI_SQLI"],"resp_fuids":["FEW63MqCqth3LH1"],"resp_mime_types":["text/html"]}]
```



Qual è il significato di queste informazioni?

Mi sono concentrato sull'uri poiché è lì che avviene la SQL Injection:
/mutillidae/index.php?page=userinfo.php&username='+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards--&&password=&user-info.php-submit

Infatti in questo uri si può notare: un **tentativo di SQL Injection**: la stringa `union select ccid, ccnumber, ccv, expiration... from credit_cards...` mostra che qualcuno sta cercando di estrarre dati di carte di credito da un database tramite manipolazione della query SQL.

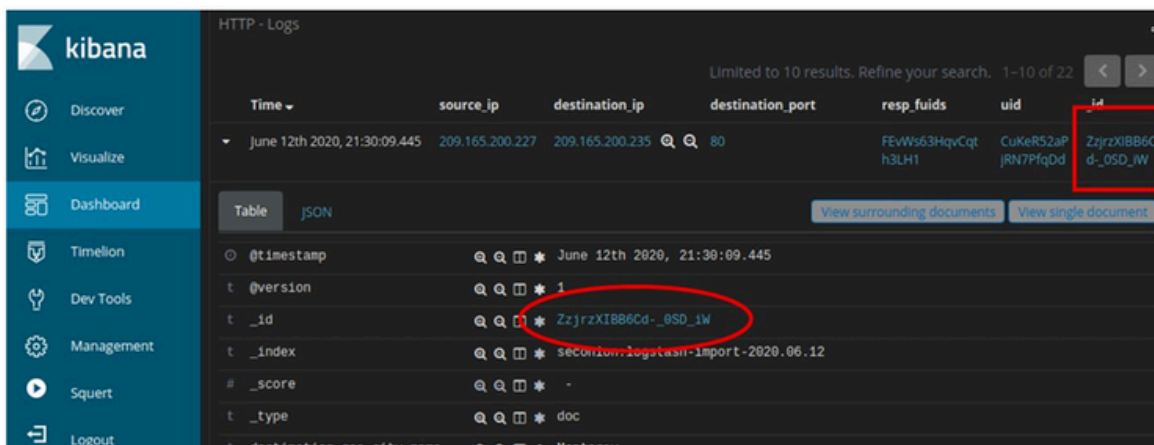
Per quanto riguarda gli altri campi do qui una breve spiegazione:

Campi principali del log

- **ts** — data/ora dell'evento (timestamp ISO).
- **uid** — identificatore univoco della connessione/flow.
- **id.orig_h** — IP sorgente (chi ha iniziato la connessione).
- **id.orig_p** — Porta sorgente (porta del client).
- **id.resp_h** — IP di destinazione (server contattato).
- **id.resp_p** — Porta destinazione (porta sul server, es. 80/443).
- **method** — verbo HTTP usato (GET, POST, ...).
- **host** — valore dell'header HTTP Host (dominio o IP target).
- **uri** — path + query richiesti (contiene il payload dell'attacco se presente).
- **referrer** — pagina di provenienza (header Referer).
- **user_agent** — stringa client/browser inviata dal client.
- **request_body_len** — lunghezza del body della richiesta (byte).
- **response_body_len** — lunghezza del body della risposta (byte).
- **status_code** — codice HTTP restituito dal server (es. 200, 404).
- **status_msg** — messaggio di stato corrispondente (es. "OK").
- **tags** — etichette/indicatori generati dall'analisi (es. HTTP::URI_SQLI).
- **resp_mime_types** — tipo MIME della risposta (es. text/html).
- **trans_depth** — profondità/numero di redirect o livelli di richiesta correlati.
- **resp_fuids** — riferimenti a file-UID generati dall'analisi (se è stato estratto/ricostruito un file).

Passo 3: Rivedere i risultati.

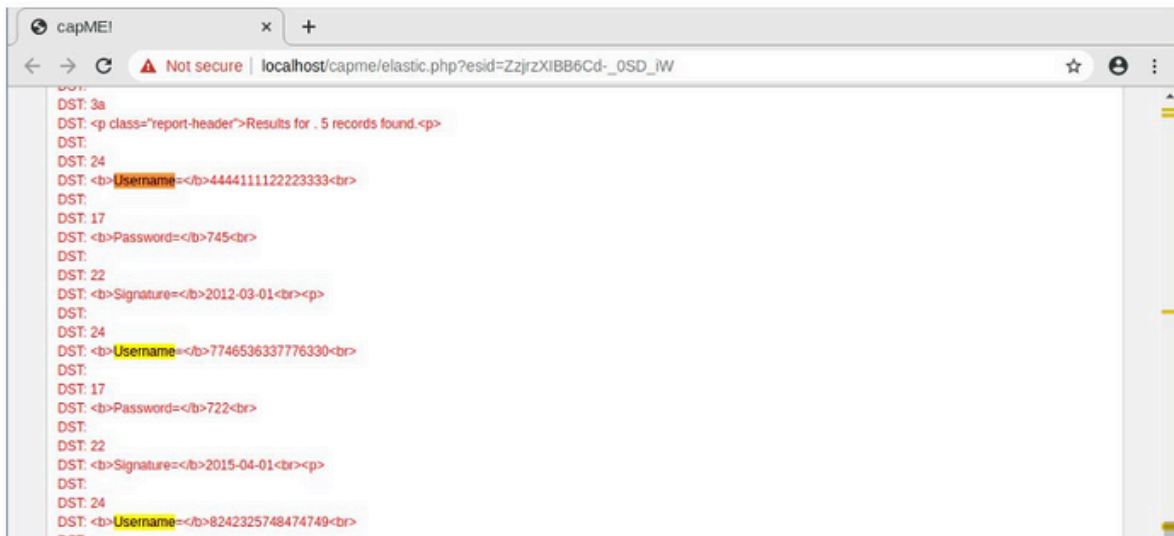
a. Alcune delle informazioni per le voci di log sono collegate ipertestualmente ad altri strumenti. Fai clic sul valore nel campo `alert_id` della voce di log per ottenere una vista diversa sull'evento.



b. Il risultato si apre in una nuova scheda del browser web con informazioni da capME!. La scheda capME! è un'interfaccia web che ti permette di visualizzare una trascrizione pcap. Il testo blu contiene le richieste HTTP inviate dalla sorgente (SRC). Il testo rosso sono le risposte dal server web di destinazione (DST).

c. Nella sezione Log entry, che si trova all'inizio della trascrizione, nota la porzione **username='+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+-+&password=** indica che qualcuno potrebbe aver tentato di attaccare il browser web usando SQL injection per bypassare l'autenticazione. Le parole chiave, **union** e **select**, sono comandi usati nella ricerca di informazioni in un database SQL. Se le caselle di input su una pagina web non sono adeguatamente protette da input illegali, gli attori della minaccia possono iniettare stringhe di ricerca SQL o altro codice che può accedere ai dati contenuti nei database collegati alla pagina web.

d. Trova la parola chiave **username** nella trascrizione. Usa **Ctrl-F** per aprire una casella di ricerca. Usa il pulsante freccia giù nella casella di ricerca per scorrere le occorrenze trovate.



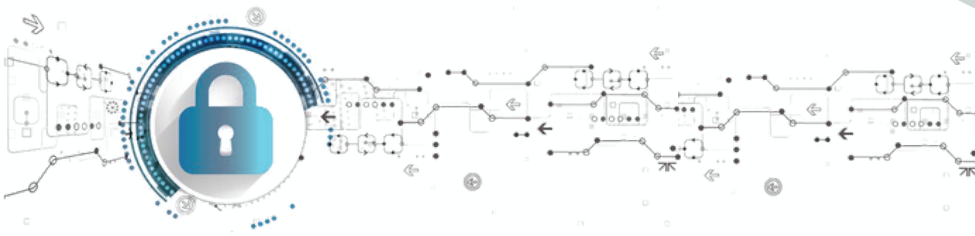
Puoi vedere dove il termine username è stato usato nell'interfaccia web visualizzata all'utente. Tuttavia, se guardi più in basso, si può trovare qualcosa di insolito.



Cosa vedi più avanti nella trascrizione riguardo ai nomi utente? Fornisci alcuni esempi di nome utente, password e firma che sono stati esfiltrati.

Come si può vedere da screenshot ci sono vari /molti username e password esfiltrati dal database.

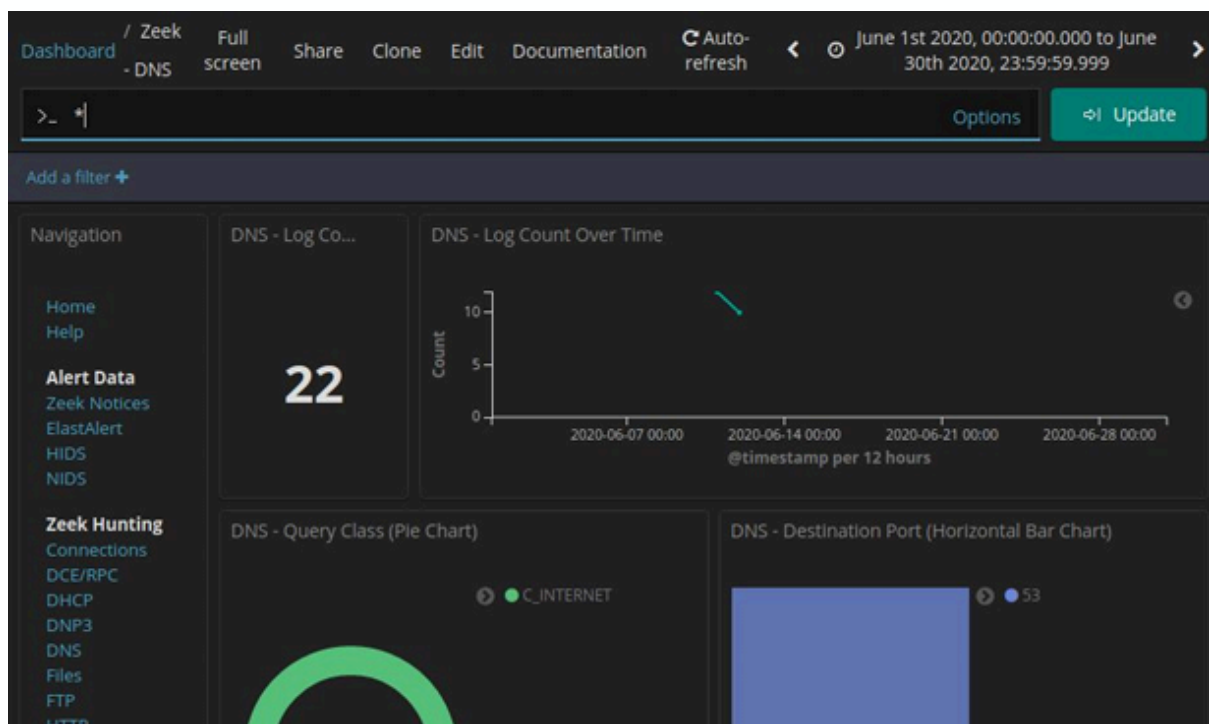
```
DST: <b>Username=</b>4444111122223333<br>
DST:
DST: 17
DST: <b>Password=</b>745<br>
DST:
DST: 22
DST: <b>Signature=</b>2012-03-01<br><p>
DST:
DST: 24
DST: <b>Username=</b>7746536337776330<br>
DST:
DST: 17
DST: <b>Password=</b>722<br>
DST:
DST: 22
DST: <b>Signature=</b>2015-04-01<br><p>
DST:
```

Parte 2 - Analizzare l'Esfiltrazione DNS.

Un amministratore di rete ha notato **query DNS** anormalmente lunghe con sottodomini dall'aspetto strano. Il tuo compito è investigare l'anomalia.

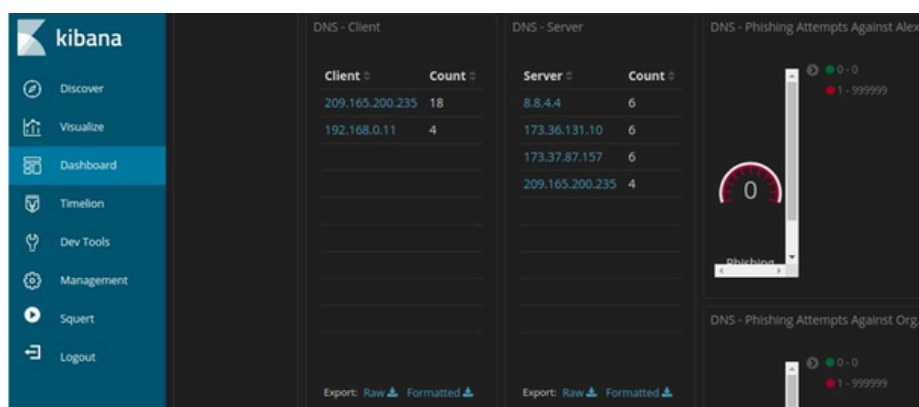
Passo 1 - **Filtrare** per traffico DNS. a. Dalla parte superiore del Dashboard Kibana, cancella eventuali filtri e termini di ricerca e fai clic su Home sotto la sezione Navigation del Dashboard. Il periodo di tempo dovrebbe ancora includere Giugno 2020. b. Nella stessa area del Dashboard, fai clic su DNS nella sezione Zeek Hunting. Nota le metriche **DNS Log Count** e il grafico a barre orizzontale Destination Port.



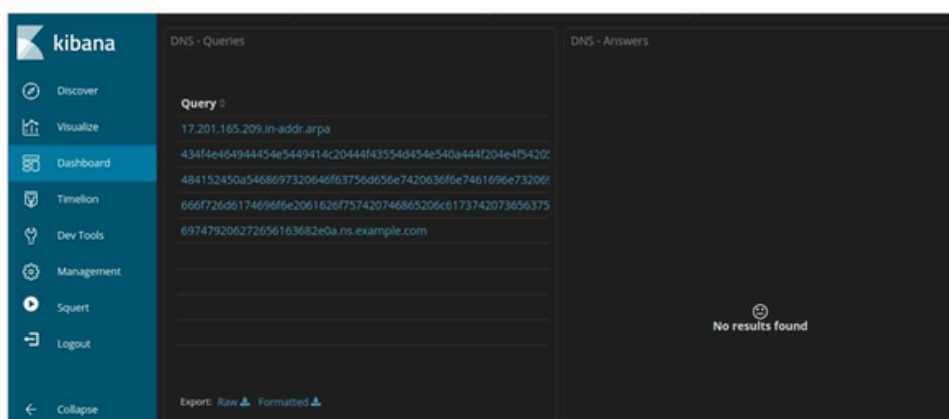
kibana

Passo 2: Rivedere le voci relative al DNS.

- Scorri verso il basso la finestra. Puoi vedere i principali tipi di query DNS. Potresti vedere record di indirizzo (record A), record Quad A di indirizzo IPv6 (AAAA), record NetBIOS (NB) e record puntatore per risolvere i nomi host (PTR). Puoi anche vedere i codici di risposta DNS.
- Scorrendo ulteriormente verso il basso, puoi vedere un elenco dei principali client DNS e server DNS basati sul conteggio delle loro richieste e risposte. C'è anche una metrica per il numero di tentativi di phishing DNS, noti anche come DNS pharming, spoofing o poisoning.



- Scorrendo ulteriormente verso il basso la finestra puoi vedere un elenco delle principali query DNS per nome di dominio. Nota come alcune delle query abbiano sottodomini insolitamente lunghi collegati a ns.example.com. Il dominio example.com dovrebbe essere investigato ulteriormente.



- Torna all'inizio della finestra e inserisci **example.com** nella barra di ricerca per filtrare per example.com e fai clic su **Update**. Nota che il numero di voci nel Log Count è minore perché la visualizzazione è ora limitata alle richieste al server example.com. (Nota: L'originale diceva di inserire 'com', ma il contesto indica di filtrare per 'example.com').

b. Naviga in **/home/analyst/Downloads**. Apri il file usando un editor di testo, come gedit. Modifica il file eliminando il testo circostante la porzione esadecimale dei sottodomini, lasciando solo i caratteri esadecimali. Assicurati di rimuovere anche le virgolette. Il contenuto del tuo file dovrebbe assomigliare alle informazioni sottostanti. Salva il file di testo modificato con il nome file originale.

```
434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053
484152450a5468697320646f63756d656e7420636f6e7461696e7320696e
666f726d6174696f6e2061626f757420746865206c617374207365637572
697479206272656163682e0a
```

c. In un terminale, usa il comando `xxd` per decodificare il testo nel file CSV e salvarlo in un file chiamato `secret.txt`. Usa `cat` per visualizzare il contenuto di `secret.txt` nella console.

```
analyst@SecOnion:~/Downloads$ xxd -r -p "DNS - Queries.csv" > secret.txt
analyst@SecOnion:~/Downloads$ cat secret.txt
```



I sottodomini delle query DNS erano sottodomini? Se no, qual è il testo?

No quello che si vede non è un sottodominio normale ma **DNS codificato** in esadecimale infatti aveva prima una lunga stringa in esadecimale e non parole.

```
DNS - Queries (1).csv
~/Downloads
Open [icon] Save [icon] - [icon] x
DNS - Queries.csv x secret.txt x DNS - Queries (1).csv x
Query, Count
"434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053.ns.example.com", 1
"484152450a5468697320646f63756d656e7420636f6e7461696e7320696e.ns.example.com", 1
"666f726d6174696f6e2061626f757420746865206c617374207365637572.ns.example.com", 1
"697479206272656163682e0a.ns.example.com", 1
```

E infatti il testo esadecimale di quei “sottodomini” decodificato era questo:

The image shows a terminal window on the left and a file viewer on the right. The terminal window displays the following commands and output:

```

analyst@SecOnion:~$ sudo dpkg-reconfigure keyboard-configuration
[sudo] password for analyst:
analyst@SecOnion:~$ sudo dpkg-reconfigure keyboard-configuration
Your console font configuration will be updated the next time your system
boots. If you want to update it now, run "setupcon" from a virtual console.
update-rc.d warning: start and stop actions are no longer supported; falling back to defaults
update-initramfs: deferring update (trigger activated)
Processing triggers for initramfs-tools (0.122ubuntu16) ...
update-initramfs: Generating /boot/initrd.img-4.15.0-91-generic
*[[B]][[AM: mdadm: /etc/mdadm/mdadm.conf defines no arrays.
analyst@SecOnion:~$ sudo so-status
Status: securityonion
  - sgql server
Status: seconion-import
  - pcap_agent (sgull)
  - snort_agent-1 (sgull)
  - barnyard2-1 (spooler, unified2 format)
Status: Elastic stack
  - so-elasticsearch
  - so-logstash
  - so-kibana
  - so-freqserver

analyst@SecOnion:~$ cd /home/analyst/Downloads
analyst@SecOnion:~/Downloads$ ls
analyst@SecOnion:~/Downloads$ ls -l
total 0
analyst@SecOnion:~/Downloads$ ls -la
total 8
drwxr-xr-x 2 analyst analyst 4096 Jul  9 2020 .
drwxr-xr-x 16 analyst analyst 4096 Sep 30 09:49 ..
analyst@SecOnion:~/Downloads$ xxd -r -p "DNS - Queries.csv" > secret.txt
analyst@SecOnion:~/Downloads$ cat secret.txt
CONFIDENTIAL DOCUMENT
  
```

The file viewer on the right shows the contents of 'secret.txt'. It is a 'CONFIDENTIAL DOCUMENT' that contains information about the last security breach. The document is titled 'DNS - Queries.csv' and contains the following text:

```

CONFIDENTIAL DOCUMENT
DO NOT SHARE
This document contains information about the last security breach.
  
```

Cosa implica questo risultato riguardo a queste particolari richieste DNS? Qual è il significato più ampio?

Questo risultato implica, ipoteticamente un **esfiltrazione** dei dati tramite DNS.

Quindi Informazioni reali sono state trasmesse **fuori** dalla rete usando DNS.

Cosa potrebbe aver creato queste query DNS codificate e perché è stato scelto il DNS come mezzo per esfiltrare dati?

Queste query DNS potrebbero essere state create da un **malware**, da uno script o un exploit che legge file, lo codifica in esadecimale, spezza la stringa della lunghezza massima consentita per un DNS e invia le query.

Perchè il DNS è spesso **poco** controllato e strutturalmente adatto a incapsulare dati in sottodomini, perciò è un mezzo ideale per l'esfiltrazione stealth che hai osservato nei log del laboratorio.